Cheatsheet AZ-305 — 01 · Identidad: licencias y gobernanza de Microsoft Entra ID

1. Licencias: qué desbloquea cada nivel

Función	Free	P1	P2	Governance (add-on)
Usuarios, grupos, SSO básico, Entra Connect	✓	✓	✓	✓
Smart Lockout (fuerza bruta / password spray)	✓	✓	✓	✓
SSPR (cambio de contraseña)	✓	✓	✓	✓
Security Defaults (MFA global, bloqueo legacy auth, todo-o-nada)	✓	—	—	—
SSPR con **writeback** a AD DS	✗	✓	✓	✓
Conditional Access (condiciones que defines tú)	✗	✓	✓	✓
Grupos dinámicos, hybrid join, Password Protection on-prem	✗	✓	✓	✓
Identity Protection (user risk / sign-in risk, CA basado en riesgo)	✗	✗	✓	✓
PIM (roles eligible, JIT, aprobación, auditoría)	✗	✗	✓	✓
Access Reviews (grupos, apps, roles, invitados)	✗	✗	✓	✓ (ampliado)
Entitlement Management (access packages)	✗	✗	✗	✓
Lifecycle Workflows (onboarding / offboarding)	✗	✗	✗	✓

Regla: "risk-based" → P2 · "just-in-time / eligible" → P2 · "access package" → Governance · "onboarding automático" → Governance · "Free edition / minimize licensing" → busca algo incluido por defecto (Smart Lockout, Security Defaults).

2. Identity Protection vs Identity Governance

	Identity Protection	Identity Governance
Pregunta	¿Esta identidad está en riesgo ahora?	¿Este acceso debería existir?
Naturaleza	Detección (ML) + respuesta vía CA	Ciclo de vida y recertificación
Señales	user risk (credenciales filtradas), sign-in risk (viaje imposible, IP anónima/malware)	pertenencia, roles, paquetes, altas y bajas
Acción típica	exigir MFA, bloquear, forzar reset	activar temporalmente, revocar, expirar, desaprovisionar
Frecuencia	continua, cada sign-in	periódica / bajo demanda
Licencia	P2	P2 (básico) / Governance (completo)

3. Las cuatro piezas de Governance

Pieza	Qué hace	Verbo del enunciado	Detalles de examen
PIM	Activación JIT de roles (Entra ID, Azure RBAC, grupos)	"temporary", "just-in-time", "eligible", "no standing access", "justification"	Incluye **alertas** (roles fuera de PIM, exceso de admins), **audit history** de activaciones y **access reviews de roles**. Recomendado con MFA + aprobación
Access Reviews	Recertificación periódica; quien no confirma, pierde el acceso	"review periodically", "self-attestation", "remove if no response", "guests"	Revisores: self, manager, designados. Recurrencia configurable. Acción por no respuesta: remove
Entitlement Management	Paquetes de acceso (grupos + apps + sitios) con solicitud, aprobación y **expiración**	"access package", "request access", "partner / external collaboration", "expire"	Catálogos, políticas por audiencia (internos / externos), connected organizations
Lifecycle Workflows	Automatiza joiner / mover / leaver	"onboarding", "offboarding", "when a user leaves"	Disparadores por atributos de RRHH (fecha de alta / baja)

Access Reviews está dentro de Governance y embebida en PIM (roles) y Entitlement (paquetes). Si las opciones ofrecen solo PIM para "revisar roles administrativos + alertas + historial" → PIM. Si ofrecen Access Reviews para "grupos / invitados" → Access Reviews.

4. Conditional Access: anatomía de una política

Bloque	Qué contiene	Ejemplos
Assignments / Conditions	a quién, qué app, desde dónde, qué dispositivo, qué riesgo	usuarios que gestionan producción, app "Microsoft Azure Management", ubicación, plataforma, sign-in risk
Grant	qué se exige para **conceder** el acceso	Require MFA · Require compliant device · Require hybrid joined device · Require approved app (AND / OR)
Session	qué pasa **después** de conceder	Sign-in frequency (ej. 14 días) · Persistent browser session · App enforced restrictions

- "Require MFA / compliant / hybrid joined" → **Grant**.
- "Reducir la frecuencia de MFA con best practices" → **Sign-in frequency (Session)**, no el legacy "Remember MFA".
- "Registrar métodos MFA" → **Authentication methods policy**, no CA.
- **Security Defaults** y CA personalizado son **excluyentes**.

5. Identidad híbrida

	PHS	PTA	ADFS
Dónde se valida la contraseña	Nube (hash sincronizado)	On-prem (agentes)	On-prem (federación)
Sobrevive caída de red on-prem	**Sí**	No	No
Requisito "password hashes solo on-prem"	✗	✓	✓
Habilita Identity Protection leaked credentials	✓	Solo si PHS también	No
Recomendación	PHS (+ Seamless SSO). PTA con PHS como backup		

- **Entra Connect Health** → alertas de fallos de sincronización.
- **"License agreement failed"** al asignar licencia → falta **Usage Location** (no se sincroniza desde AD DS).
- **Dominio personalizado:** debe ser público y verificable con **TXT**; .local nunca sirve.
- **UPN sufijos no enrutables** → añadir UPN suffix público antes de sincronizar.
- **Entra Domain Services** → LDAP / Kerberos / NTLM **dentro de Azure** sin VPN a on-prem, alimentado desde Entra ID.
- **Application Proxy + KCD** → publicar app on-prem con IWA/Kerberos, SSO, sin VPN.
- **Lighthouse** → gestionar recursos de **otros tenants** sin cuentas guest. **B2B** → invitar **usuarios** como guests.
- **Workday provisioning:** 1 app puede cubrir empleados y contratistas con mapeo condicional (IIF); 1 provisioning agent por dominio destino (mínimo).

6. Árbol de decisión

```
¿Qué pide el enunciado?
├─ Detectar riesgo / credenciales filtradas / viaje imposible ..... Identity Protection (P2)
├─ Exigir MFA o dispositivo al entrar ............................. Conditional Access · Grant (P1)
├─ Cada cuánto repetir MFA ........................................ CA · Session · Sign-in frequency
├─ Qué métodos MFA pueden registrar ............................... Authentication methods policy
├─ Rol temporal con justificación / aprobación ..................... PIM (P2)
├─ Revisar periódicamente grupos / invitados / apps ................ Access Reviews (P2)
├─ Revisar roles administrativos + alertas + historial ............. PIM (P2)
├─ Paquete de recursos que se solicita y expira .................... Entitlement Management (Governance)
├─ Altas y bajas automáticas ...................................... Lifecycle Workflows (Governance)
├─ Fuerza bruta sin licencia ...................................... Smart Lockout (Free)
└─ MFA para todos sin granularidad y sin licencia .................. Security Defaults (Free)
```

7. Señales → respuesta

Enunciado	Respuesta
"risk-based", "leaked credentials", "atypical travel"	Identity Protection
"Just-In-Time", "eligible", "standing permissions"	PIM
"every three months", "self-attest", "removed if no response"	Access Reviews
"inactive admins list" (solo listar)	Sign-in logs / Entra Workbooks
"access package", "request access", "expire after"	Entitlement Management
"hybrid joined device AND MFA"	Grant control en la política existente
"reduce MFA prompts, 14 days, best practice"	Sign-in frequency
"Free tenant", "minimize licensing", "password spray"	Smart Lockout
"custom domain", ".local"	Dominio público con TXT; .local es distractor
"LDAP", "no VPN allowed"	Entra Domain Services
"MSP manages multiple tenants"	Lighthouse

8. Errores a evitar

1. Confundir P1 con P2: PIM, Identity Protection y Access Reviews son **P2**.
2. Elegir Identity Protection para "exigir MFA a todos siempre" → eso es CA Grant.
3. Elegir PIM para "revisión periódica de un grupo" cuando Access Reviews está en las opciones.
4. Elegir Session control para exigir MFA → Session regula después de conceder.
5. Elegir .local como dominio personalizado.
6. Elegir B2B cuando el enunciado prohíbe guest accounts.